WEB APPLICATION PENETRATION TEST — VULNERABILITY REPORT

Use of Weak MD5 Password Hashing

Finding NVP-010 · **Medium**

Product: PHPGurukul News Portal Project in PHP and MySQL — V4.1

Assessment target: http://localhost/newsportal/newsportal/

Technology: Apache 2.4.58 · PHP 8.2.12 · MariaDB 10.4.32 (DB user: root)

Assessment date: 2026-10-31

Classification: CONFIDENTIAL — authorised lab assessment (review draft)

Document Control

Finding ID	NVP-010
Vulnerability	Use of Weak MD5 Password Hashing
Severity	**Medium**
CVSS 4.0	6.9 `CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N`
CWE	CWE-916 (Weak Password Hash); CWE-327
OWASP	A02:2021 Cryptographic Failures
CVE verification	No matching publicly assigned CVE was identified for this specific finding and product/version during the research performed.
Status	CONFIRMED (manually validated & re-verified)

1. Executive Summary

Administrator passwords are stored as unsalted MD5. MD5 is fast and broken for password storage, so any hash disclosure (e.g. via NVP-002 or NVP-016) leads to rapid offline cracking.

2. Affected Target

Affected URL	/admin/index.php, /admin/forgot-password.php, /admin/add-subadmins.php
Affected parameter	AdminPassword storage
Affected role	n/a
Authentication	n/a

3. Technical Description

Login compares md5($_POST["password"]); forgot-password and add-subadmins store md5() hashes. MD5 is unsalted and extremely fast to brute-force/rainbow-table. Combined with the exposed DB dump (NVP-016) or UNION SQLi (NVP-002), stored hashes are trivially recoverable. (change-password.php inconsistently uses bcrypt, which also breaks login — evidence crypto is unmanaged.)

4. Root Cause Analysis

```
admin/index.php:11 $password=md5($_POST['password']); ... (same in forgot-password.php:10, add-subadmins.php:15).
```

5. Preconditions

Disclosure of a stored hash (available via NVP-002 / NVP-016).

6. Proof of Concept — Step-by-Step Reproduction

1. Obtain a stored AdminPassword MD5 (e.g. from the downloadable newsportal.sql — NVP-016 — or UNION SQLi — NVP-002).
2. Observe it is a 32-hex unsalted MD5.
3. Such hashes are crackable offline at very high rates (no cracking performed here — out of harmless scope and unnecessary to prove the weakness).

7. HTTP Request Evidence

```
n/a (storage weakness; see NVP-016 for hash retrieval).
```

8. HTTP Response Evidence

```
newsportal.sql INSERT INTO tbladmin ... AdminPassword='<32-hex md5>'
```

9. Proof of Concept — Visual Evidence

> **Evidence note:** Confirmed from source (md5 usage) and from the seeded hash visible in the exposed newsportal.sql dump.

10. Actual Security Impact

Disclosed password hashes can be reversed quickly, enabling credential reuse and account takeover; weak hashing also means breach disclosure compromises all accounts.

Exploitation complexity	Low once a hash is disclosed.
Realistic attack scenario	Attacker reads tbladmin via NVP-002/016, cracks the MD5, and logs in legitimately.

11. Remediation Recommendations

Use password_hash(PASSWORD_DEFAULT/bcrypt/argon2id) with per-user salts; migrate existing hashes on next login; standardise one hashing scheme across login/reset/create.

Secure code example

```
$hash = password_hash($plain, PASSWORD_DEFAULT);
if (password_verify($plain, $stored)) { if (password_needs_rehash($stored, PASSWORD_DEFAULT)) { /*
rehash */ } }
```

12. Retesting Procedure

Inspect stored hashes; a fixed system stores bcrypt/argon2 ($2y$/$argon2) values, not 32-hex MD5.

13. References

- CWE-916
- CWE-327
- OWASP WSTG-CRYP-04
- OWASP A02:2021

14. Conclusion

Confirmed weak MD5 password storage. Verified from source and the exposed seed hash.